

DSAR Portal & Consent Hub Architecture & Flow Specification

End-to-End Privacy Automation, Statutory Retention Rules & Apache Kafka Event Streaming

Platform: Segmento Universal Data Protection	Runtime: Node.js 18+ (tested v26.x)	Automated Tests: 20/20 Passed (234/234, 100%)
Legal Mandates: GDPR, DPDP 2023, PDPA, CCPA	Integration: Apache Kafka Dual-Mode Broker	Date: October 06, 2026

1. Executive Summary & Statutory Legal Distinction

The platform coordinates automated Data Subject Access Requests (DSAR) across distributed cloud microservices, operational databases, CRM leads, and analytical data lakes. A core design requirement is the strict operational distinction between **Full Account Deletion** and **Granular Consent Withdrawal**:

LEGAL DIMENSION	ACCOUNT DELETION (GDPR Art. 17 / DPDP Sec. 12)	CONSENT WITHDRAWAL (GDPR Art. 7(3) / DPDP Sec. 6(4))
Account State	Account is TERMINATED and permanently erased.	Account remains ACTIVE & RETAINED .
Data Impact	PII erased or salt-anonymized across operational DBs.	Transactional data kept; processing permissions revoked.
Downstream Effect	Multi-connector purge across primary tables & caches.	Halts real-time marketing, AI training & telemetry streams.
Statutory Locks	Financial invoices locked under RBI / GST 7-10 yr hold.	No financial hold overrides needed; user can re-opt-in anytime.
Cryptographic Proof	Signed Cryptographic Deletion Certificate (CERT-DEL-XXXX).	Cryptographic Proof Receipt (WDR-XXXX) + Suppression Hash.

2. System Architecture: The 6-Layer Decoupled Stack

The architecture decouples request intake from execution, statutory policy enforcement, and message-driven synchronization through 6 independent layers:

LAYER	PRIMARY RESPONSIBILITIES, PROTOCOLS & SOURCE MODULES
Layer 1: User & Interface Layer	DSAR Portal Web UI: 8 integrated subviews (Intake Form, Master Queue, Discovery Engine, Execution Hub, Verification, Team/SLA Settings, Consent Matrix, and Kafka Stream Monitor). Built in responsive modular JavaScript (frontend/public/js/consent-hub.js).
Layer 2: API Gateway & Security Layer	Segmento Gateway: OAuth 2.0 / OIDC Authorization Server with RS256 JWT tokens, JWKS discovery endpoint (/well-known/jwks.json), RBAC scope guards (consent:withdraw, deletions:create), sliding-window rate limiting, and X-Correlation-ID tracing header injection.
Layer 3: Core Business Orchestration	Orchestration Engines: DSAR Orchestrator (backend/services/dsar-service.js), Statutory Policy Engine (dsar-policy-service.js), Multi-Lead SLA Assignment (dsar-assignment-service.js), and Consent Service (consent-service.js).
Layer 4: Data & Persistence Layer	Multi-Store Persistence: PostgreSQL instance with zero-downtime local SQL fallback (backend/database/udps_local_db.json), legal hold billing escrows for RBI/GST statutory retention, and persistent consent registry (consent-ledger.json).
Layer 5: Event & Integration (Kafka)	Apache Kafka Streaming: Dual-mode zero-config partition broker with 3 topics (consent.events.withdrawal, .grant, .dlq), key-partition hashing by subject_id, consumer group offset commits, and 5 downstream connector consumers.
Layer 6: Verification & Proof Layer	Cryptographic Receipts: SHA-256 immutable withdrawal receipts, suppression tokens (SHA-256 hashed identifiers ensuring zero plain PII is stored downstream), signed deletion certificates, and append-only tamper-proof audit trails.

8 Modular Subviews in the DSAR Portal Workspace

- **1. Intake Workspace:** Create new erasure/DSAR requests with scope pills (Full Erasure vs Granular Consent).
- **2. Master Request Queue:** Real-time KPI tracker across all 7 lifecycle stages with statutory deadline countdowns.
- **3. Discovery & Impact Engine:** Automated cross-database PII discovery scanning tables, caches, and file stores.
- **4. Execution & Orchestration:** Multi-connector task execution with multi-department subtask delegation.
- **5. Verification & Certificates:** Post-execution residue queries and downloadable signed SHA-256 certificates.
- **6. Team & SLA Settings Hub:** Department assignments, statutory SLA deadlines, and Nodemailer SMTP webmail inboxes.
- **7. Consent Hub Matrix:** Granular 5-category processing matrix toggles and instant cryptographic receipt generator.
- **8. Kafka Stream Monitor:** Real-time Kafka topic partition viewer, consumer lag metrics, and stream replay button.

3. End-to-End Workflow Process Flows

Flow A: 7-Stage Privacy Deletion Lifecycle (GDPR Art. 17 / DPDP Sec. 12)

- **Stage 1 (CREATED):** Subject initiates request via DSAR Intake. Validated with email, customer ID, and jurisdiction.
- **Stage 2 (DISCOVERY_PENDING → DISCOVERED):** System executes automated scans across databases, caches, CRM, and analytics tables to find all records associated with the subject identifier.
- **Stage 3 (POLICY EVALUATION):** Policy engine evaluates statutory retention obligations (RBI/GST 7-10 yr billing ledgers, active loans, fraud investigations).
- **Stage 4 (PLAN_READY):** Generates a 6-action plan (PERMANENT_DELETE, ANONYMIZE, STATUTORY_FREEZE, CACHE_INVALIDATION, SYNC_DOWNSTREAM, NOTIFY_LEADS).
- **Stage 5 (AWAITING_APPROVAL → APPROVED):** Dispatches email notifications to Department Leads (CRM, Security, Engineering) via Nodemailer SMTP / Ethereum test inboxes. DPO grants execution approval.
- **Stage 6 (EXECUTING → EXECUTED):** Connectors execute atomic deletions and freeze retained financial ledgers in statutory escrow.
- **Stage 7 (VERIFICATION → COMPLETED):** Runs post-deletion verification check to verify zero residual operational PII and issues a signed Cryptographic Deletion Certificate (CERT-DEL-2026-XXXX).

Flow B: Granular Consent Withdrawal & Kafka Downstream Enforcement (GDPR Art. 7(3))

- **Step 1 (User Request):** Subject selects specific categories to revoke (e.g. AI Model Training, Promotional Marketing) in the DSAR Consent Hub.
- **Step 2 (Gateway Authentication):** POST /api/v1/consent/withdraw passes through Segmento Gateway. Token is validated via RS256 signature and scope guard (consent:withdraw).
- **Step 3 (State Transition):** Consent Management Service transitions category state from GRANTED → WITHDRAWN. Crucially, Account status remains ACTIVE (Retained).
- **Step 4 (Cryptographic Receipt):** Generates SHA-256 immutable proof receipt (WDR-2026-XXXX) and hashed suppression token.
- **Step 5 (Kafka Event Emission):** Producer partitions message by hashing subject_id (md5 % 3) and publishes to topic 'consent.events.withdrawal' with correlation headers.
- **Step 6 (Downstream Consumer Enforcement):** 5 concurrent connector consumer groups receive the event and execute enforcement actions immediately:
 - - *CRM (Salesforce/HubSpot):* Sets DoNotContact and ConsentWithdrawn flags.
 - - *Marketing (SendGrid/Twilio):* Hashes email into global unsubscribe & STOP suppression list.
 - - *Data Lake (Snowflake):* Mutes telemetry stream and purges behavioral tracking partition.
 - - *AI / ML Pipeline (Vertex AI):* Issues EXCL-AI-XXXX exclusion token under EU AI Act Art. 53.
 - - *Third-Party Systems:* Emits IAB Do-Not-Sell partner syndication webhooks.
- **Step 7 (Consumer Offset Commit & DLQ):** Consumer groups commit partition offsets. Errors trigger retry routing to Dead Letter Queue (consent.events.dlq).
- **Step 8 (Live Dashboard Reflection):** Event stream log and connector cards update in real time with ACK_COMMITTED status.

4. Downstream Connector Enforcement Specifications

When consent withdrawal events stream through Apache Kafka, 5 consumer groups independently process and apply compliance actions across downstream systems:

CONNECTOR	TARGET SYSTEM	CONSUMER GROUP	ACTION ENFORCED ON WITHDRAWAL	STATUTORY BASIS
1. CRM Connector	Salesforce CRM, HubSpot, Braze	crm-enforcement-group	Sets DoNotContact and ConsentWithdrawn on account & lead records.	GDPR Art. 21 / DPDP Sec. 6
2. Marketing Platform	SendGrid, Twilio SMS Gateway	marketing-platform-group	Inserts SHA-256 suppression hash into global unsubscribe & STOP list.	ePrivacy Directive / CAN-SPAM
3. Data Lake & Warehouse	Snowflake Lakehouse, GA4	datalake-snowflake-group	Mutes telemetry stream; purges partition: analytics.customer_tracking.	GDPR Art. 6(1)(a)
4. AI / ML Pipeline	Vertex AI, OpenAI Fine-Tuning	aiml-training-exclusion-group	Commits EXCL-AI-XXXX token to omit customer chats from LLM datasets.	EU AI Act Art. 53 / GDPR Art. 9
5. Third-Party Systems	Ad Exchanges, Affiliate Brokers	thirdparty-syndication-group	Dispatches IAB Do-Not-Sell / Do-Not-Share webhooks to partner endpoints.	CCPA / CPRA Do Not Sell

Dead Letter Queue (DLQ) & Stream Replay Mechanism

Automatic DLQ Routing: If any downstream connector experiences connection failure, timeouts, or API schema rejection, the message is automatically republished to consent.events.dlq with retry count headers (x-retry-count) without halting other connector groups.

Audit Stream Replay: Compliance officers can trigger POST /api/v1/consent/kafka/replay from offset 0, which re-emits historical withdrawal events across all consumer groups for regulatory audits or downstream connector recovery.

5. Complete REST API Reference

All API endpoints are mounted on the Express application and guarded by Segmento OAuth 2.0 / OIDC middleware:

METHOD	ENDPOINT PATH	REQUIRED SCOPE	DESCRIPTION & FUNCTIONALITY
GET	/api/v1/consent/categories	consent:read	Returns all 5 granular consent categories and system metadata.
GET	/api/v1/consent/status/:id	consent:read	Retrieves current consent matrix and history for subject identifier.
POST	/api/v1/consent/withdraw	consent:withdraw	Executes granular withdrawal, streams Kafka event, and yields SHA-256 receipt.
POST	/api/v1/consent/grant	consent:grant	Re-grants consent for specified categories (Opt-in) and streams to Kafka.
GET	/api/v1/consent/receipt/:id	consent:read	Fetches verified cryptographic proof receipt by receiptId.
GET	/api/v1/consent/history/:id	consent:read	Retrieves complete chronological audit trail of consent events.
GET	/api/v1/consent/ledger	consent:admin	Master consent ledger view across all data subjects for DPO review.
GET	/api/v1/consent/kafka/metrics	consent:read	Returns cluster broker health, topics, high watermarks, and consumer lag.
GET	/api/v1/consent/kafka/events	consent:read	Live Kafka event stream log with optional ?topic= and ?limit= parameters.
GET	/api/v1/consent/kafka/connectors	consent:read	Status, processed counts, and health of all 5 downstream connector consumers.
GET	/api/v1/consent/kafka/ledger	consent:read	Enforcement ledger showing all downstream automated system actions.
POST	/api/v1/consent/kafka/replay	consent:withdraw	Replays event stream from specific offset across consumer groups.
POST	/api/v1/deletions	deletions:create	Creates new DSAR erasure request (Status: CREATED).
GET	/api/v1/deletions/:id	deletions:read	Fetches full DSAR request record with stage, findings, and history.
POST	/api/v1/deletions/:id/discover	deletions:create	Executes automated cross-system PII discovery scan across DBs and caches.
POST	/api/v1/deletions/:id/plan	deletions:create	Generates 6-action deletion plan with statutory retention evaluation.
POST	/api/v1/deletions/:id/approve	deletions:admin	Approves deletion plan for execution.
POST	/api/v1/deletions/:id/execute	deletions:admin	Executes atomic deletions and freezes financial invoices in escrow.
GET	/api/v1/deletions/:id/certificate	deletions:read	Downloads signed cryptographic deletion certificate with SHA-256 proof.

6. Automated Testing & Verification Report

The codebase has been verified with comprehensive unit, integration, and security tests. All 20 test suites pass with 100% success rate:

TEST SUITE FILE	SCOPE & REGULATORY VERIFICATION	TESTS	RESULT
tests/kafka-consent-integration.test.js	Kafka partition hashing, producer headers, 5 connectors, DLQ failover & replay.	13	PASS (100%)
tests/consent-withdrawal.test.js	GDPR Art. 7(3) state machine, 5 categories, SHA-256 receipts, and opt-in.	9	PASS (100%)
tests/gateway-oauth.test.js	RS256 JWT validation, JWKS, rate limiting, and RBAC scope guards.	17	PASS (100%)
tests/data-deletion-api.test.js	Full 10-endpoint DSAR deletion REST platform and 7-stage lifecycle.	15	PASS (100%)
tests/dsar-policy.test.js	RBI Master Direction & GST statutory retention rules (7-10 yr locks).	9	PASS (100%)
15 Other Protection & DSAR Suites	AES-256-GCM encryption, database masking, email search, discovery, certs.	171	PASS (100%)
TOTAL ACROSS ALL SUITES	Complete End-to-End Enterprise Privacy Platform Verification	234	234/234 (100%)

Compliance Conclusion & Audit Readiness

The Segmento UDPS DSAR Portal and Consent Hub architecture provides enterprise-grade, cryptographically verifiable proof of compliance. With automated Kafka event distribution, multi-store transactional persistence, and zero-downtime failover mechanisms, the system is fully prepared for regulatory audits and live multi-tenant production operations.